

Governance, Risk & Compliance Requirements - Intelligent Invoice Exception Resolution

AI Governance Framework

Current State: No formal AI governance framework exists - Organization is ISO 27001 certified (information security) - Have IT governance committee that meets monthly - No specific policies for AI/ML systems - Previous chatbot pilot had no governance oversight (contributed to failure)

Required AI Governance:

1. AI Ethics & Oversight Committee

- **Composition:** CFO (chair), IT Director, Compliance Officer, AP Manager, Legal Counsel
- **Frequency:** Monthly meetings, ad-hoc for critical issues
- **Responsibilities:**
 - Approve agent deployment and major capability changes
 - Review agent performance and decision quality
 - Address ethical concerns (bias, fairness, transparency)
 - Escalate high-risk decisions or patterns

2. Agent Decision Authority

- **Fully Autonomous** (no approval required):
 - Variances <5% for suppliers with 2+ year relationship and good performance history
 - Standard items (non-critical, readily available)
 - Total invoice value <\$10K
- **Autonomous with Notification** (decide first, notify human after):
 - Variances 5-10% for trusted suppliers
 - Invoice value \$10K-\$50K
 - Non-standard items with clear contract terms
- **Human-in-the-Loop** (human approval required before action):
 - Variances >10%
 - Invoice value >\$50K
 - New suppliers (<6 months relationship)
 - Critical items (production materials, IT equipment)
 - Policy violations or contract disputes

3. Responsible AI Principles

- **Transparency:** All agent decisions must be explainable
- **Fairness:** No bias in treatment of suppliers based on size, location, or relationship
- **Accountability:** Clear ownership for agent decisions (AP Manager accountable)
- **Privacy:** Respect supplier confidentiality and data protection
- **Safety:** Guardrails to prevent financial loss or relationship damage

Regulatory & Compliance Requirements

Applicable Regulations:

1. **Australian Taxation Office (ATO) Requirements**
 - Invoice retention: 7 years (digital format acceptable)
 - GST reporting: Accurate tax calculation and reporting
 - Audit trail: Complete record of invoice processing and adjustments
 - **Agent Impact:** Agents must maintain compliant records, cannot delete or modify historical data
2. **Corporations Act 2001**
 - Financial record keeping: 7-year retention
 - Director duties: Reasonable care in financial management
 - Audit requirements: External auditor access to all financial records
 - **Agent Impact:** Agent decisions are part of financial records, must be auditable
3. **Privacy Act 1988 (Australian Privacy Principles)**
 - Collection: Only collect necessary supplier personal information
 - Use: Use data only for invoice processing purposes
 - Security: Protect personal information from unauthorized access
 - Access: Suppliers can request access to their data
 - **Agent Impact:** Agents must not expose PII in logs, emails must be professional and appropriate
4. **Payment Card Industry Data Security Standard (PCI-DSS) - Limited applicability**
 - We don't store credit card data, but some suppliers provide card details for refunds
 - Must ensure agents don't log or expose card numbers
 - **Agent Impact:** Mask any payment card data in agent logs and communications

Data Sovereignty: - All data must remain within Australia - Cannot use AI models that send data to overseas servers - Prefer AWS Sydney region for all infrastructure - Need data residency guarantees from AWS

Cross-Border Considerations: - Some suppliers are international (New Zealand, Singapore, US) - Email communication crosses borders (acceptable for business purposes) - Need to ensure compliance with supplier's local data protection laws

Risk Management

Enterprise Risk Framework: Based on ISO 31000 - Risk appetite defined by Board annually - Risk register maintained by Compliance Officer - Quarterly risk reviews with executive team

Risk Appetite for Agentic AI:

Risk Category	Appetite Level	Rationale
Process automation (standard cases)	High	Clear rules, low financial impact
AI decision-making (with oversight)	Medium	Acceptable with human review capability
Autonomous financial decisions	Low	Only for low-value, low-risk scenarios
Supplier relationship management	Medium	Important but recoverable if issues arise
Data privacy and security	Very Low	Zero tolerance for breaches

Key Risks Identified:

1. **Incorrect Payment Decisions** (High Impact, Medium Likelihood)
 - **Risk:** Agent approves invoice with unacceptable variance, leading to overpayment
 - **Impact:** Financial loss, audit findings, supplier disputes
 - **Mitigation:**
 - Strict autonomy boundaries (only <5% variance for trusted suppliers)
 - Human review of all decisions >\$10K
 - Weekly audit of agent decisions by AP Manager
 - Rollback capability if pattern of errors detected
2. **Supplier Relationship Damage** (Medium Impact, Medium Likelihood)
 - **Risk:** Agent sends inappropriate or unprofessional email to supplier
 - **Impact:** Damaged relationship, supplier refuses to do business, reputational harm
 - **Mitigation:**
 - Email templates reviewed by Supplier Relationship Manager
 - Tone and sentiment analysis before sending
 - Human review of emails to key suppliers (initially)
 - Escalation if supplier responds negatively
3. **Data Breach or Privacy Violation** (High Impact, Low Likelihood)
 - **Risk:** Agent exposes confidential supplier data or PII
 - **Impact:** Privacy breach, regulatory penalties, reputational damage, loss of supplier trust
 - **Mitigation:**
 - Data masking in logs and non-production environments
 - Access controls and encryption
 - Regular security assessments
 - Incident response plan

4. **Agent Drift or Performance Degradation** (Medium Impact, Medium Likelihood)
 - **Risk:** Agent performance degrades over time, making poor decisions
 - **Impact:** Increased errors, escalations, manual intervention required
 - **Mitigation:**
 - Continuous monitoring of decision accuracy
 - Weekly performance reviews
 - A/B testing of agent versions
 - Rollback to previous version if performance drops
5. **Vendor Fraud via Agent Manipulation** (High Impact, Low Likelihood)
 - **Risk:** Malicious supplier manipulates agent through crafted emails or invoices
 - **Impact:** Fraudulent payments, financial loss
 - **Mitigation:**
 - Anomaly detection for unusual patterns
 - Human review of first-time suppliers
 - Verification of bank account changes
 - Fraud detection rules in agent logic

Insurance Coverage: - Current cyber insurance: \$5M coverage (general cyber incidents) - **Gap:** No specific AI liability coverage - **Action:** Exploring AI-specific insurance for autonomous decision-making risks

Data Governance

Data Ownership Model: - **Finance Department** owns invoice and payment data - **Procurement Department** owns vendor master data and contracts - **IT Department** manages data infrastructure and access controls - **Compliance Officer** oversees data governance policies

Data Classification:

Classification	Examples	Agent Access	Retention
Confidential	Vendor bank accounts, pricing agreements, contract terms	Read-only, masked in logs	7 years
Internal	Invoice amounts, PO numbers, approval decisions	Read/write	7 years

Classification	Examples	Agent Access	Retention
PII	Vendor contact names, emails, phone numbers	Read-only, masked in logs	7 years
Public	Vendor company names, addresses	Read-only	7 years

Data Lineage & Provenance: - **Current:** Manual tracking, inconsistent - **Required:** - Track data sources for agent decisions (which invoice, PO, GRN, email, contract) - Timestamp all data access and modifications - Maintain chain of custody for audit purposes - Link agent decisions back to source data

Data Quality Management: - **Current:** SAP enforces data validation (95%+ accuracy for structured data) - **Challenge:** Unstructured data (emails, PDFs) has variable quality - **Required:** - Data quality checks before agent processing - Confidence scoring for extracted data - Human review for low-confidence data - Feedback loop to improve extraction accuracy

Master Data Management: - Vendor master data managed in SAP - **Challenge:** Synchronization with agent knowledge base - **Required:** Real-time or near-real-time sync of vendor data changes

Model Governance & Explainability

Model Documentation: - **Required:** Document all agent configurations, prompts, and decision logic - **Version Control:** Track changes to agent behavior over time - **Change Log:** Record why changes were made and expected impact

Model Versioning: - **Semantic Versioning:** Major.Minor.Patch (e.g., 1.2.3) - **Major:** Significant behavior changes requiring re-approval - **Minor:** Capability enhancements, backward compatible - **Patch:** Bug fixes, no behavior change

Explainability Requirements: - **Decision Explanation:** Agent must explain why it made each decision - Example: “Accepted 3% variance because: (1) Supplier X has 2-year relationship with 98% accuracy, (2) Contract allows up to 5% variance, (3) Item is standard office supplies (low risk)” - **Confidence Scoring:** Agent should indicate confidence level in decisions - **Alternative Options:** Show what other decisions were considered and why rejected - **Human-Readable:** Explanations must be understandable by AP clerks, not just technical staff

Bias Detection & Mitigation: - **Concern:** Agent might treat small suppliers differently than large suppliers - **Monitoring:** - Track decision patterns by

supplier size, location, relationship length - Quarterly bias audits by Compliance Officer - Compare agent decisions to human decisions for similar cases - **Mitigation:** - Explicit fairness rules in agent logic - Remove supplier size from decision factors (unless relevant to risk) - Regular review of decision patterns

Model Performance Monitoring: - **Accuracy:** % of agent decisions validated as correct by human review - **Drift Detection:** Monitor for changes in decision patterns over time - **Escalation Rate:** Track % of cases escalated to humans (should decrease over time) - **Feedback Loop:** Incorporate human corrections into agent learning

Model Decommissioning: - **Trigger:** If agent accuracy drops below 90% for 2 consecutive weeks - **Process:** 1. Immediate rollback to previous version 2. Root cause analysis by IT and AP teams 3. Fix and re-test in staging environment 4. Re-approval by AI Ethics Committee before re-deployment

Audit & Traceability

Audit Requirements:

1. **Internal Audit** (Quarterly)
 - Review sample of agent decisions (100 exceptions per quarter)
 - Verify decision accuracy and compliance with policies
 - Check audit trail completeness
 - Report findings to CFO and Audit Committee
2. **External Audit** (Annual)
 - PwC audits financial statements
 - Must provide evidence of invoice processing controls
 - Agent decisions are part of financial controls
 - Need to demonstrate agent reliability and oversight
3. **ATO Audit** (Ad-hoc, every 3-4 years)
 - Tax authority may audit GST reporting and invoice records
 - Must provide complete audit trail for any invoice
 - Agent decisions must be explainable to auditors

Traceability Requirements:

Complete Audit Trail for each exception: 1. **Initial Detection:** When and how discrepancy was identified 2. **Investigation:** What data sources agent accessed (invoice, PO, GRN, emails, contracts) 3. **Communication:** All emails sent/received, with timestamps 4. **Decision:** What decision was made, why, confidence level, alternatives considered 5. **Approval:** If escalated, who approved and when 6. **Outcome:** Final resolution, payment status, lessons learned

Immutable Logs: - All agent actions logged to immutable storage (S3 with versioning and object lock) - Logs cannot be modified or deleted (compliance requirement) - 7-year retention period - Logs must be searchable for audit purposes

Right to Explanation: - Suppliers can request explanation of any decision affecting their invoices - AP team must be able to retrieve and explain agent decisions - Explanations must be provided within 5 business days

Security Governance

Security Certifications: - **ISO 27001:** Certified, renewed annually (last renewal: June 2024) - **SOC 2 Type II:** Last completed 18 months ago (due for renewal) - **Required:** Extend certifications to cover agentic AI systems

Security Assessments:

1. **Penetration Testing** (Annual)
 - External firm tests for vulnerabilities
 - Last test: March 2024 (no critical findings)
 - **Required:** Include agent infrastructure in next test (Q2 2025)
2. **Vulnerability Scanning** (Quarterly)
 - Automated scanning of infrastructure
 - Remediation within 30 days for high-severity issues
 - **Required:** Scan agent containers and dependencies
3. **Security Awareness Training** (Monthly)
 - All staff complete monthly security training
 - **Required:** Add AI-specific security topics (prompt injection, data leakage)

Incident Response: - **Documented Plan:** Incident response plan updated annually - **Notification Requirement:** 4-hour notification to CFO for data breaches - **Security Operations Center (SOC):** Operates 8am-6pm AEST (business hours only) - **After-Hours:** On-call rotation for critical incidents - **Required:** Extend incident response plan to cover agent-specific incidents - Agent making fraudulent decisions - Agent data breach or PII exposure - Agent manipulation by malicious actors

Security Monitoring: - **Current:** Basic monitoring of infrastructure and network - **Required for Agents:** - Monitor for unusual agent behavior (anomaly detection) - Alert on high-risk decisions or escalations - Track data access patterns - Detect potential prompt injection or manipulation attempts

Change Management & Approval

Change Approval Board (CAB): - **Composition:** IT Director (chair), AP Manager, Compliance Officer, Security Manager - **Frequency:** Weekly meetings - **Scope:** All production changes to IT systems

Change Categories:

1. **Standard Changes** (Pre-approved)
 - Minor agent prompt refinements
 - Configuration updates within approved parameters

- No CAB approval required, but must be logged
- 2. **Normal Changes** (CAB approval required)
 - Agent capability enhancements
 - New decision rules or thresholds
 - Integration changes
 - **Lead Time:** 5 business days notice
- 3. **Emergency Changes** (CIO approval)
 - Critical bug fixes
 - Security patches
 - Agent rollback due to performance issues
 - **Lead Time:** Immediate, with post-implementation review

Deployment Approval Requirements:

1. **User Acceptance Testing (UAT)**
 - AP Manager must sign off on agent behavior
 - Test with 100 historical exceptions (known outcomes)
 - Minimum 95% accuracy required for approval
2. **Security Review**
 - Security Manager reviews for vulnerabilities
 - Penetration test for major changes
 - Sign-off required before production deployment
3. **Compliance Review**
 - Compliance Officer reviews for regulatory compliance
 - Verify audit trail and explainability
 - Sign-off required for changes affecting financial decisions

Impact Assessment: - **Business Impact:** Effect on AP team, suppliers, payment timelines - **Technical Impact:** Integration changes, performance, scalability - **Security Impact:** New vulnerabilities, data exposure risks - **Compliance Impact:** Regulatory or audit implications

High-Impact Changes (require executive approval): - Changes to agent autonomy boundaries - New agent capabilities (e.g., negotiating payment terms) - Integration with new systems - Changes affecting >\$1M in monthly invoice processing

Additional Governance Details

AI Ethics Policy (To be formalized): - **Responsible AI Principles:** 1. **Transparency:** All agent decisions must be explainable to users, suppliers, and auditors 2. **Fairness:** No discrimination based on supplier size, location, or relationship length 3. **Accountability:** Clear ownership for agent decisions (AP Manager accountable, CFO ultimately responsible) 4. **Privacy:** Respect supplier confidentiality, minimize data collection, secure data handling 5. **Safety:** Guardrails to prevent financial loss, relationship damage, or compliance violations 6. **Human Oversight:** Humans remain in control, agents augment not replace human judgment - **Enforcement:** - AI Ethics Committee reviews compliance

quarterly - Violations escalated to CFO and Board if material - Corrective actions required within 30 days - Repeat violations may result in agent suspension

Bias Audit Methodology: - **Quarterly Bias Audits** (Compliance Officer leads): 1. **Data Collection:** Extract 500 agent decisions from past quarter 2. **Segmentation Analysis:** Group by supplier size, location, relationship length, industry 3. **Statistical Testing:** Chi-square tests for significant differences in decision patterns 4. **Threshold:** >10% difference in approval rates between groups triggers investigation 5. **Root Cause Analysis:** If bias detected, analyze agent logic and training data 6. **Remediation:** Adjust agent rules, retrain on balanced data, add fairness constraints 7. **Validation:** Re-test with new data to confirm bias eliminated - **Metrics Tracked:** - Approval rate by supplier size (small <\$100K/year, medium \$100K-\$1M, large >\$1M) - Approval rate by supplier location (domestic vs international) - Approval rate by relationship length (<1 year, 1-3 years, >3 years) - Average resolution time by supplier segment - **Reporting:** Quarterly bias audit report to AI Ethics Committee and CFO

Third-Party Risk Management: - **AWS Risk Assessment:** - **Data Residency:** Confirmed AWS Sydney region keeps data in Australia - **Security Certifications:** AWS has ISO 27001, SOC 2, PCI-DSS (meets our requirements) - **SLA:** 99.9% uptime for Bedrock, Lambda, DynamoDB (acceptable) - **Data Protection:** AWS GDPR compliance covers Australian Privacy Act requirements - **Vendor Lock-in:** Mitigated by using standard APIs, can migrate to other cloud providers - **Annual Review:** IT and Compliance review AWS security posture annually - **Other Vendors:** - **SAP:** Existing vendor, no additional risk from agent integration - **Microsoft:** Existing vendor (Office 365), Graph API covered by existing agreement - **Professional Services:** AWS ProServe covered by standard consulting agreement - **Ongoing Monitoring:** - Subscribe to AWS security bulletins and compliance updates - Quarterly review of vendor security incidents - Annual vendor risk assessment refresh

Agent Liability Framework: - **Legal Responsibility:** - **Organization:** Ultimately liable for all agent decisions (standard corporate liability) - **AP Manager:** Accountable for agent oversight and performance (operational accountability) - **IT Director:** Responsible for agent technical reliability and security - **Individual Staff:** Not liable for agent decisions (protected by corporate liability) - **Insurance Coverage:** - **Cyber Insurance:** \$5M coverage includes AI-related incidents (confirmed with insurer) - **Professional Liability:** \$10M coverage for financial errors (includes automated decisions) - **Directors & Officers:** \$20M coverage for executive decisions (includes AI governance) - **Indemnification:** - Organization indemnifies AP staff for agent decisions made within policy - Staff not indemnified for intentional misconduct or policy violations - **Dispute Resolution:** - Supplier disputes handled through standard commercial dispute process - Agent decisions treated same as human decisions for legal purposes - Audit trail and explainability support legal defense if needed

Supplier Notification Policy: - **Disclosure Requirement:** Yes, Australian

Privacy Act requires disclosure of automated decision-making - **Notification Approach:** - Email to all active suppliers (200+) before agent deployment - Explain AI-driven communication and benefits (faster, consistent, 24/7) - Provide opt-out option (human-only communication) - Include contact for questions or concerns - **Ongoing Disclosure:** - Email signature: “This email may be generated by AI and reviewed by our AP team” - Website disclosure: “We use AI to improve invoice processing efficiency” - Contract updates: Add AI disclosure clause to new supplier agreements - **Opt-Out Process:** - Suppliers can request human-only communication (estimated <5%) - Flag in vendor master data, agents skip these suppliers - Review opt-out requests quarterly, offer to re-enable AI communication

Data Retention for Agent Logs: - **Financial Records:** 7 years (Corporations Act requirement) - Invoice data, PO data, GRN data, payment records - Agent decisions and explanations (part of financial audit trail) - **Agent Training Data:** 3 years (operational requirement) - Historical exception resolutions used for agent learning - After 3 years, anonymize and archive for pattern analysis - Delete after 7 years (align with financial records retention) - **Email Communications:** 7 years (compliance requirement) - All supplier emails (sent and received by agents) - Stored in Exchange Online (existing retention policy) - **Agent Logs:** 90 days active, 7 years archive (audit requirement) - Active logs in CloudWatch for troubleshooting - Archive to S3 Glacier after 90 days - Delete after 7 years - **Personal Data:** Delete upon request (Privacy Act requirement) - Supplier contact information deleted if supplier requests - Anonymize historical data to remove PII

Model Retraining Governance: - **Retraining Triggers:** - Quarterly scheduled retraining on new exception data - Ad-hoc retraining if performance degrades (accuracy <95%) - Major process changes (new suppliers, contract terms, approval workflows) - **Approval Process:** 1. **Data Review:** Compliance Officer reviews training data for bias, quality, completeness 2. **Test Results:** IT team tests retrained agent on validation set (95% accuracy required) 3. **Bias Check:** Run bias audit on retrained agent decisions 4. **UAT:** AP Manager tests retrained agent with 50 real exceptions 5. **Approval:** AI Ethics Committee approves retraining (or rejects if issues found) 6. **Deployment:** Phased rollout (10% → 50% → 100% over 2 weeks) - **Safeguards:** - Training data must be balanced (no over-representation of any supplier segment) - Human-reviewed decisions only (no agent-generated training data) - Validation set separate from training set (20% holdout) - Rollback plan if retrained agent underperforms

Cross-Border Data Flow: - **Supplier Countries:** Australia (80%), New Zealand (10%), Singapore (5%), US (3%), UK (2%) - **Data Protection Laws:** - **New Zealand:** Privacy Act 2020 (similar to Australia, compatible) - **Singapore:** Personal Data Protection Act (requires consent for data collection) - **US:** No federal privacy law, but California CCPA applies to some suppliers - **UK:** UK GDPR (requires data protection agreement) - **Compliance Approach:** - **Standard Contractual Clauses:** Include in supplier agreements for interna-

tional suppliers - **Data Minimization:** Only collect necessary data (invoice details, contact info) - **Consent:** Obtain consent for data processing in supplier onboarding - **Data Localization:** All data stored in Australia (AWS Sydney region) - **Transfer Mechanism:** Email communication crosses borders (acceptable for business purposes) - **Risk Assessment:** Low risk (business-to-business communication, no sensitive personal data)

Agent Decommissioning Plan: - **Trigger Conditions:** - Agent performance consistently below 90% accuracy for 6 months - Regulatory changes prohibit autonomous decision-making - Business decision to discontinue agentic AI - Technology obsolescence (better alternatives available) - **Decommissioning Process:** 1. **Transition Plan:** 3-month transition to manual processing or alternative solution 2. **Knowledge Preservation:** Export agent knowledge base to documentation 3. **Data Archive:** Archive all agent decisions and logs to S3 Glacier (7-year retention) 4. **System Shutdown:** Deactivate agents, delete runtime infrastructure 5. **Audit Trail:** Maintain audit trail of decommissioning for compliance - **Historical Decisions:** Remain valid and auditable (part of financial records) - **Lessons Learned:** Document successes, failures, and recommendations for future AI initiatives

Regulatory Change Monitoring: - **Monitoring Approach:** - **Legal Team:** Subscribe to AI regulation updates (federal and state) - **Industry Associations:** Participate in finance industry AI working groups - **Compliance Officer:** Quarterly review of regulatory landscape - **External Counsel:** Annual legal review of AI compliance - **Key Regulations to Monitor:** - **Australian AI Ethics Framework:** Government guidance on responsible AI - **Privacy Act Amendments:** Potential AI-specific privacy requirements - **Financial Services Regulations:** ASIC guidance on AI in financial services - **International Standards:** ISO/IEC standards for AI governance - **Response Process:** 1. **Impact Assessment:** Evaluate how new regulations affect agent operations 2. **Gap Analysis:** Identify compliance gaps and required changes 3. **Remediation Plan:** Develop plan to address gaps (timeline, resources, costs) 4. **Implementation:** Update agent logic, policies, and procedures 5. **Validation:** Verify compliance through testing and audit - **Timeline:** 6-month buffer to implement changes before regulations take effect